Universidad Tecnológica Nacional

Facultad Regional Resistencia



Trabajo Práctico Nº 2 “Aplicación de Recursos”

Profesores:

- Montiel, Raul Alejandro.
- Ramirez, Rosina.
- Soria Ojeda, Claudia.

Integrantes del grupo:

- Esquivel, Emilio.
- Fernández, Facundo Nahuel.
- Gomez, Christian.
- Medina, Mariano
- Retamozo Enrique, Agustin Ruben.
- Robales, Lautaro.
- Orgoñ, Nahiara.
- Velazco Gez Schegtel, Juan Ignacio.

1. Aplicación de RRHH

Punto A

La implementación exitosa de las estrategias de Sistemas de Información (SI) y Tecnologías de la Información (TI) definidas en las fases anteriores —especialmente el desarrollo del ERP Vial Integral y el SIG GeoVial— requiere mucho más que la simple adquisición de tecnología; exige una **profunda transformación organizacional**.

El análisis estratégico de la situación actual reveló que el actual Departamento de Informática de la Dirección de Vialidad Provincial posee una estructura orientada exclusivamente al soporte técnico tradicional. Esta disposición, donde el área de desarrollo de software se encuentra subordinada a la de servidores, resulta insuficiente y limitante para liderar un proyecto de modernización y soberanía tecnológica a nivel provincial.

Para que el área de TI tenga la capacidad operativa y el peso político necesarios para ejecutar este Plan Estratégico, se propone una reestructuración integral basada en metodologías modernas de recursos humanos y gobernanza tecnológica.

A continuación, se presenta gráficamente la transición desde el esquema actual hacia la nueva **Dirección de TICs**, seguida de su fundamentación estratégica detallada:



Para garantizar el éxito de la implementación del Plan Estratégico, resulta imperativo reestructurar el área tecnológica actual. La nueva propuesta organizativa se fundamenta bajo tres dimensiones críticas:

1. Desde el punto de vista de la UBICACIÓN

- **Modelo Adoptado:** Ubicación **Centralizada** con **Prestación Externa (Outsourcing) de Infraestructura**.
- **Justificación:** Se propone un alto grado de centralización en la Dirección de TICs, la cual dependerá exclusivamente de la Alta Gerencia (Administrador General). Al hablar de un modelo centralizado, los Sistemas de Información se convierten en un **servicio interno** para todas las áreas de Vialidad. Por lo tanto, la toma de decisiones estratégicas, las políticas de TI y la asignación de prioridades residirán únicamente en la Dirección, sin transferir ni delegar responsabilidades a las delegaciones zonales.

  Para que este grado de centralización se cumpla eficientemente, se aplicará el concepto de **Supercentros**. En lugar de tener servidores físicos dispersos en las regionales, se consolidará toda la infraestructura en una única instalación. Para ello, se realizará el *outsourcing* (prestación externa) del alojamiento de los servidores (Data Center) con ECOM Chaco, manteniendo la gobernanza y administración lógica centralizada en la DVP.

2. Desde el punto de vista del ROL

- **Transición Operativa:** El análisis del TP1 demostró que lo que hace el departamento actualmente es muy básico (soporte técnico tradicional). Por lo tanto, se plantea una transición evolutiva.
- **Justificación:** El área dejará de ser un simple centro de reparaciones para convertirse en un **Proveedor de Servicios Internos**. Una vez estabilizado este servicio, el rol evolucionará hacia la conformación de una verdadera **Fábrica de Soluciones y Datos**. En este nuevo rol, el equipo de TI se enfocará en el desarrollo "In-House" (ERP) y en el procesamiento de la información espacial (GeoVial), abandonando el rol pasivo para convertirse en el motor de producción digital de la organización.

3. Desde el punto de vista de la ORGANIZACIÓN

- **Modelo Adoptado:** Departamentalización enfocada en **Bases de Datos, Proyectos y Operaciones**.
- **Justificación:** Para que la estructura acompañe realmente el nuevo rol de "Fábrica de Soluciones y Datos", no basta con una departamentalización funcional clásica. Las funciones deben resaltar la producción de software y el manejo de datos. Por ello, la Dirección de TICs se organizará en los siguientes departamentos:
  - **Dpto. de Gestión de Base de Datos y Analítica:** Área core de la nueva estructura. Serán los responsables del mantenimiento del Motor Espacial

(PostGIS), la administración del SIG GeoVial, el gobierno de los datos y los tableros de Inteligencia de Negocios (BI).

- **Dpto. de Desarrollo de Soluciones:** Funcionará como la "Fábrica de Software". Su función exclusiva será la programación, testing y mantenimiento del código del *ERP Vial Integral*, aplicando metodologías ágiles.
- **Dpto. de Operaciones y Servicios Internos:** Área encargada de controlar el cumplimiento del contrato de *Outsourcing* (Supercentro en ECOM Chaco), garantizar la Ciberseguridad y brindar el servicio de Mesa de Ayuda a los usuarios internos.

Propuesta de Tercerización de Gestión (Outsourcing Estratégico)

Como definimos en la Fase 4 que el desarrollo será **In-House** (para garantizar soberanía tecnológica), **no vamos a tercerizar la creación del software**.
Sin embargo, siendo realistas respecto al hardware y a las limitaciones del Estado, **se propone tercerizar el Alojamiento de la Infraestructura Crítica (IaaS - Infraestructura como Servicio)**.

Se propone un convenio interinstitucional de tercerización con **ECOM Chaco**.

Esquematización de los aspectos del Contrato (SLA - Acuerdos de Nivel de Servicio):

Si tercerizamos los servidores del ERP y el GeoVial en el Data Center de ECOM Chaco, el contrato debe incluir los siguientes aspectos críticos:

1. **Disponibilidad y Uptime (Tiempo de actividad):** El contrato debe exigir un nivel de disponibilidad del **99.5%** en horario de oficina (07:00 a 14:00) para soportar el pico de la UPN de consultas GIS y el cierre de certificaciones a fin de mes.
2. **Escalabilidad Elástica (Planificación de Capacidad):** Una cláusula donde el proveedor (ECOM) garantice la posibilidad de aumentar la Memoria RAM y CPU de las Máquinas Virtuales en menos de 24 horas ante un pedido justificado de la DVP (para soportar picos transaccionales inesperados).
3. **Seguridad y Backups (RTO y RPO):**
   - *RPO (Punto de Recuperación):* Copias de seguridad automáticas de la base de datos de obras (PostgreSQL) cada 12 horas.
   - *RTO (Tiempo de Recuperación):* En caso de caída catastrófica del servidor, el proveedor tiene un máximo de 4 horas para restaurar el servicio del ERP.
4. **Penalizaciones (Nivel de Servicio):** Si el servidor de GeoVial se cae a fin de mes (impidiendo certificar obras) y se incumple el SLA, la DVP exigirá compensaciones económicas o bonificaciones sobre el costo mensual del alojamiento.

Punto B

Descripción y Análisis de Cargo por Competencias: Director de TICs
Nivel del Puesto: Directivo / Conducción Estratégica (Clase XIX o Superior)
Área: Dirección de Tecnologías de la Información y Comunicaciones (TICs)
Misión del Puesto: Liderar, planificar e implementar la estrategia e infraestructura tecnológica de Vialidad Provincial del Chaco de cara al futuro. Actuar como un socio estratégico capaz de alinear la digitalización, la conectividad territorial de los campamentos viales y la despapelización de los procesos administrativos con los objetivos y el plan de obras de la organización.

I. Atribuciones y Responsabilidades del Puesto (Enfoque Alles)

De acuerdo con la metodología de Martha Alles, el descriptivo de puesto debe reflejar tanto las tareas habituales de conducción como el rol activo de gestión de personas bajo su cargo:

1. Definición de Políticas Tecnológicas: Diseñar, proponer y liderar el plan informático de la institución (sistemas, servidores, telecomunicaciones de delegaciones y soporte territorial).
2. Liderazgo de Jefes: Conducir, motivar y alinear a los Jefes de Departamento bajo su dependencia directa (Sistemas, Infraestructura y Soporte).
3. Gestión Estratégica del Cliente Interno: Trabajar coordinadamente con todas las áreas del organismo (Operaciones, Delegaciones de Zonas, Finanzas y Recursos Humanos) facilitando herramientas digitales eficaces.
4. Desarrollo del Talento del Área: Participar activamente en la selección, evaluación de desempeño y diseño de planes de carrera y entrenamiento experto del personal técnico de la Dirección.

II. Perfil de Competencias Requeridas

Bajo la estructura de la Trilogía de Competencias, los cargos directivos deben evaluarse a través de tres niveles de competencias abiertas en grados uniformes (donde el Grado A representa el nivel de desarrollo superior y el Grado B un nivel muy alto sobre el promedio).

1. Competencias Cardinales

(Requeridas a toda la organización, pero exigidas en su máxima expresión para este rol directivo):

- Adaptabilidad a los cambios del entorno (Grado A): Capacidad para diseñar la estrategia y las políticas destinadas a promover en toda la Dirección la habilidad de identificar y comprender los cambios del contexto. Implica la conducción de la tecnología en épocas difíciles y restrictivas, anticipando tendencias (como la ciberseguridad o el trabajo híbrido en campamentos viales) y dando aliento a los equipos.
- Compromiso (Grado A): Capacidad para definir la visión, misión y valores del área y generar en todos los integrantes del departamento la capacidad de

sentirlos como propios. Implica ser un referente absoluto en disciplina personal, alta productividad y superación de las expectativas.

- Ética y sencillez (Grado A): Capacidad para estructurar métodos de trabajo transparentes, no burocráticos y simples de entender. Implica ser congruente entre el decir y el hacer, promoviendo un clima ético intachable y de confianza en el manejo de la información pública.

2. Competencias Específicas Gerenciales

(Exclusivas para roles con personal a cargo; en este caso, al ser un "líder de líderes"):

- Liderazgo Ejecutivo (Grado A): Capacidad para definir y comunicar la visión informática, asumiendo el liderazgo de equipos técnicos diversos y complejos. Implica actuar como un líder de líderes, guiando y entrenando a los Jefes de Departamento, evaluando sus desempeños y facilitando la toma de decisiones.
- Visión Estratégica (Grado A): Capacidad para conducir su Dirección comprendiendo que la organización es un sistema integral, donde las acciones o caídas de sistemas repercuten inmediatamente en el funcionamiento global de la provincia. Permite fijar objetivos retadores a largo plazo alineados a la planificación estratégica general.
- Liderazgo para el Cambio (Grado A): Capacidad para idear y diseñar la transformación digital del organismo y lograr que parezca deseable y motivadora para los empleados y directivos (stakeholders). Implica promover activamente la innovación eliminando la burocracia.

3. Competencias Específicas por Área

(Requeridas por la familia de puestos técnicos y de interacción del área de TICs):

- Influencia y Negociación (Grado B): Capacidad para persuadir utilizando argumentos técnicos sólidos y honestos ante el Directorio u otros ministerios. Implica acercar posiciones para asegurar partidas presupuestarias o priorizar proyectos tecnológicos bajo la premisa ganar-ganar.
- Manejo de Crisis (Grado A): Capacidad para definir estrategias y planes de contingencia eficaces para identificar y administrar situaciones críticas de presión, conflicto o fallas graves de conectividad en la provincia. Implica resolver con urgencia las contingencias protegiendo el negocio vial y la seguridad informática.
- Credibilidad Técnica (Grado B): Capacidad para dominar la especialidad tecnológica mediante fundamentos actualizados y experiencia concreta. Permite generar confianza plena en el Directorio y los colaboradores de otras áreas, convirtiéndose en un receptor de consulta clave.

III. Proceso de Evaluación y Detección de Brechas (Inventario)

Para el nombramiento o la transición del personal actual a este rol bajo el nuevo organigrama propuesto, Martha Alles indica que se debe realizar una evaluación diagnóstica inicial o Inventario de Competencias:

1. Detección de Brechas: Se comparará el perfil del candidato seleccionado con los grados requeridos en este análisis (por ejemplo, si el postulante posee un Liderazgo Ejecutivo en *Grado C* y se requiere *Grado A*, existe una brecha o *gap* de desarrollo).
2. Entrevista por Incidentes Críticos (BEI): Se sugiere evaluar estas competencias mediante entrevistas estructuradas, solicitando al candidato que relate de manera detallada proyectos complejos del pasado donde haya tenido que liderar otros jefes o resolver caídas críticas de sistemas.
3. Planes de Codesarrollo: Una vez identificadas las brechas, se deberán implementar acciones de codesarrollo y tutorías para acelerar el crecimiento del directivo en sus competencias blandas (Liderazgo y Negociación) antes y durante la asunción formal del cargo.

2. Aplicación de SI/TI

Punto A

Aplicar a **Molero** es ideal para analizar la **Infraestructura y Prestaciones** de Vialidad Provincial (DVP).

La planificación de la carga de trabajo (Workload) y la capacidad de TI en una organización se divide generalmente en tres niveles evolutivos: **Nivel de Componente (Operativo), Nivel de Sistema (Táctico) y Nivel de Negocio (Estratégico)**.

Análisis del Nivel de Prestaciones e Infraestructura

1. Situación Actual de la DVP (AS-IS): Nivel de Componente / Sistema

Actualmente, respecto a las prestaciones de sus sistemas e infraestructura, la Dirección de Vialidad Provincial se encuentra estancada en un nivel básico/intermedio.

- **Enfoque Reactivo:** La planificación de la carga se hace en función de "apagar incendios" o mantener vivos los sistemas aislados (Silos). Si el sistema de *Stock* o *Viaticar* funciona lento, Informática simplemente mejora la memoria de esa computadora o servidor específico (Planificación a Nivel de Componente).
- **Falta de Visión Transversal:** Los sistemas actuales no exigen un estrés de infraestructura coordinado. Son sistemas transaccionales simples (texto y planillas). Al depender de un sistema tercerizado para las obras ("Consorcio"), la organización delegó la carga más pesada, perdiendo el control de su propia infraestructura misional.

2. El Problema de mantenerse en este nivel

Al estar en un nivel táctico/operativo de planificación de carga, la infraestructura actual de la DVP es **incapaz de soportar los objetivos estratégicos a futuro**. Si hoy se intentara instalar el mapa GIS (GeoVial) en los servidores actuales, la red colapsaría porque no existe una planificación de la capacidad gráfica ni de procesamiento simultáneo de datos espaciales.

3. La Situación Futura con nuestro Proyecto: El salto al Nivel de Negocio

El Plan Estratégico que diseñamos obliga a la DVP a evolucionar hacia el nivel máximo propuesto por Molero: **La Planificación de la Carga orientada al Negocio**

- Con la implementación del **ERP Vial In-House y el SIG GeoVial**, el Departamento de Informática ya no planificará comprando computadoras sueltas.
- Deberá planificar la infraestructura (Máquinas Virtuales, PostgreSQL, Servidores GeoServer) basándose en las **transacciones del negocio real**: *¿Cuántos ingenieros van a renderizar mapas al mismo tiempo? ¿Cuántos playeros van a cargar combustible simultáneamente en el interior de la provincia a través de la VPN?*
- La infraestructura deja de ser un gasto reactivo para convertirse en una arquitectura elástica (escalable) que da soporte directo a la construcción de rutas y al control del Fondo Provincial.

Punto B

Una UPN es la métrica de negocio (no técnica) que estresa a la infraestructura. En lugar de decir "necesito más RAM", decimos "necesito procesar X cantidad de esta UPN".

1. ¿Cuáles son las UPN de nuestro Proyecto Futuro (ERP + SIG)?

Para dimensionar los servidores de la Fase 4, tomamos las siguientes UPN críticas:

UPN 1: Certificaciones de Obra

- **Definición:** El documento o expediente digital que avala el avance físico-financiero de un proyecto. La cantidad de certificaciones emitidas es la variable de volumen que define esta UPN.
- **Fundamentación:** El volumen de este archivo crece cíclicamente impulsado por el *core business* de la organización. A mayor cantidad de obras viales en ejecución, mayor es el número de certificaciones acumuladas en la base de datos del ERP, lo que demanda capacidad de almacenamiento (disco). A su vez, por el comportamiento interactivo del sistema, la necesidad de trabajar esta UPN durante los días de cierre contable (cruzar

datos, calcular curvas de inversión) exige al servidor un alto consumo de CPU y memoria RAM para procesar las transacciones de manera ágil.

UPN 2: Mapas (Inventario Espacial)

- **Definición:** La representación geoespacial (capas vectoriales, polígonos y nodos) de la infraestructura vial. La cantidad y complejidad geométrica de los mapas conforman la variable de volumen de esta UPN.
- **Fundamentación:** El archivo de mapas tiene un comportamiento de crecimiento directamente subordinado al negocio principal de Vialidad. A medida que se construyen nuevas rutas o caminos, los mapas crecen, demandando mayor espacio físico en disco. Luego, dado que el GIS es un sistema casi interactivo, la forma en que el sistema trabaja esta UPN incrementa la exigencia de infraestructura: a mayor crecimiento de los mapas, mayor será la demanda de memoria RAM y procesamiento gráfico requerida cada vez que el usuario ejecute la petición de renderizar dicho archivo en su pantalla.

UPN 3: Ensayos de Laboratorio

- **Definición:** El resultado técnico físico-mecánico obtenido de una muestra de material (asfalto, suelo, hormigón). La cantidad de ensayos registrados es la variable con la que se refleja la capacidad de trabajo de la Dirección de Tecnología Vial.
- **Fundamentación:** La base de datos de esta UPN crece en proporción directa a las obras en construcción, ya que cada kilómetro de ruta nueva exige la validación constante de sus materiales. El incremento ininterrumpido de este archivo demanda almacenamiento a largo plazo para auditar garantías de obra. Asimismo, cuando el sistema interactúa con esta UPN para procesar y emitir certificados de calidad cruzando cientos de registros estadísticos, se estresa la capacidad de procesamiento (CPU) del servidor.

2. Elaboración de los Gráficos de Carga (Para 2 UPN)

En la teoría de prestaciones, el comportamiento de la carga varía según el tiempo (horas del día o días del mes).

GRÁFICO A: Carga de la UPN 1 - "Certificaciones de Obra" (ERP)

- **Comportamiento:** Es una **Carga Cíclica o Transaccional Concentrada**. En Vialidad, las obras no se certifican todos los días a toda hora. Se hace un "corte" a fin de mes, por lo que el sistema recibe un pico masivo de uso en unos pocos días.
- **Eje X (Tiempo):** Días del mes (del 1 al 30).
- **Eje Y (Volumen de Carga):** Cantidad de Certificaciones procesadas.

- **Forma de la curva:**
    - Días 1 al 20: Carga casi plana, muy baja (Carga Valle).
    - Días 21 al 25: Comienza a subir.
    - **Días 25 al 30: Pico máximo extremo**. Todos los inspectores y empresas cargando datos para cobrar antes del cierre de mes.

Volumen de UPN (Certificaciones)

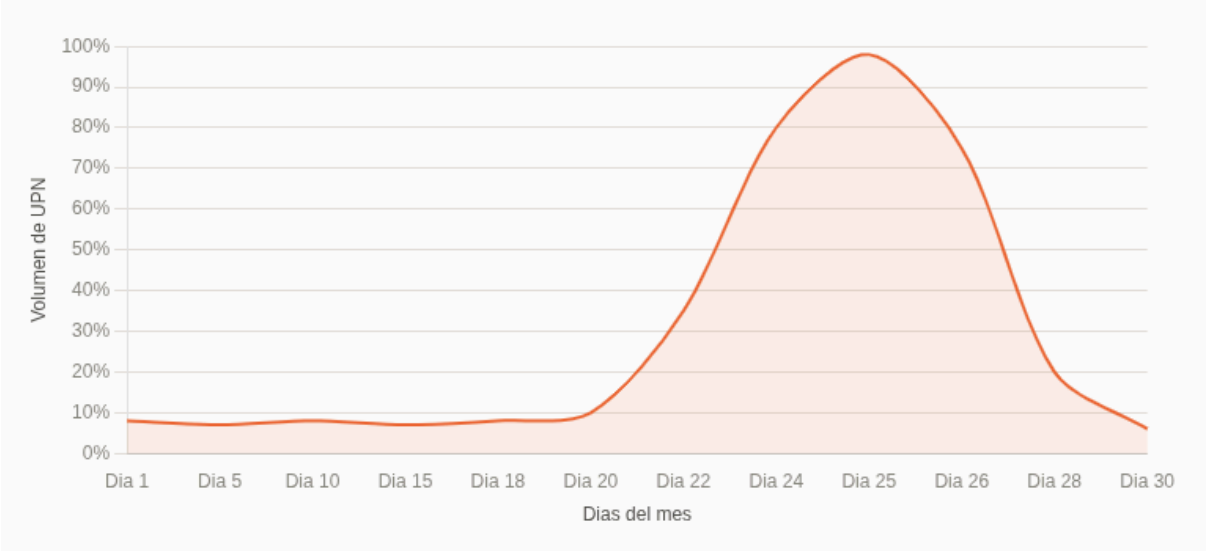


GRÁFICO B: Carga de la UPN 3 - "Ensayos de Laboratorio"

- **Comportamiento de la Carga:** Es una **Carga Interactiva con Picos de Procesamiento (Batch-like)**. La carga no es plana durante la mañana, sino que tiene picos específicos cuando los laboratoristas vuelcan los resultados de los ensayos en el sistema y generan los certificados en PDF.
- **Eje X (Tiempo):** Horas del día (00:00 a 24:00 hs).
- **Eje Y (Volumen de Carga):** % de Demanda de procesamiento sobre la UPN Ensayos.
- **Descripción de la curva:**
    - **07:00 a 10:00 hs:** Carga media-baja. Los técnicos están en el laboratorio físico haciendo las pruebas (lejos de la computadora).
    - **10:30 a 12:30 hs: Picos de Alta Demanda.** Los técnicos vuelven a sus escritorios, ingresan masivamente los resultados de los ensayos al sistema y el Director solicita la generación de los Certificados de Calidad (lo que estresa la CPU para cruzar los datos).
    - **13:00 en adelante:** La carga cae a su nivel base al finalizar la jornada del laboratorio.

Demanda de procesamiento (UPN Ensayos)



3. Seguridad de SI/TI

Fase I: Identificación de Riesgos

En esta fase se relevan los activos de información vulnerables de la DVP, sus debilidades intrínsecas y las fuentes de amenaza potenciales que pueden atentar contra la confidencialidad, integridad y disponibilidad del entorno tecnológico.

- **Activos vulnerables**:
  - **Hardware e Infraestructura**:
    - Servidores virtualizados de producción alojados en el Data Center de ECOM Chaco
    - Servidores locales en Sede Central DVP
    - Equipamiento de red (switches, routers, firewalls)
    - Computadoras y redes en las 5 Delegaciones Zonales
    - Tablets/móviles para el despacho de combustible (**SiCC Móvil**).
  - **Software**:
    - Sistema **ERP Vial Integral** desarrollado *In-House*
    - Sistema de Información Geográfica **SIG GeoVial** (GeoServer / PostGIS)
    - Motor de Base de Datos PostgreSQL
    - Clientes VPN
  - **Datos / Información**:
    - Datos financiero-contables de certificaciones de obras públicas
    - Cartografía espacial y capas de rutas viales

        - Registros de consumo y despacho de combustible
        - Padrón de contratistas y datos del persona

- **Vulnerabilidades**
    - Inestabilidad o falta de cifrado adecuado en los accesos remotos de las Delegaciones Zonales.
    - Conexiones no seguras en las zonas rurales para la operación de dispositivos móviles (tablets de SiCC).
    - Falta de capacitación y concientización en ciberseguridad por parte del personal administrativo e inspectores de obra. (vulnerabilidad de ingeniería social / phishing).
    - Alta concentración de datos críticos en un único proveedor externo de infraestructura (ECOM Chaco).

Amenazas:

Elemento	Fisica	Lógica
Accidental	● Incendios, cortes prolongados de energía eléctrica o acumulación temporal de agua o inundaciones en Data Center / Delegaciones Zonales	● Errores no intencionados en la carga de certificaciones de obra ● Fallas o bugs en actualizaciones del ERP Vial ● Desconfiguración de la VPN ● Filtración de correos electrónicos
Deliberada	● Robo de tablets/equipos de medición en campamentos viales ● Sabotaje de cableado de red o servidores locales	● Infección por Ransomware/Malware ● Ataques de denegación de servicio (DoS/DDoS) ● Acceso no autorizado para alterar montos de certificaciones o desviar cupos de combustible ● Virus

Fase II: Análisis del Riesgo

Evaluación del impacto potencial de las amenazas y calcula la pérdida financiera o de servicio esperada para la DVP

1. Cálculo de la exposición anual de pérdidas (ALE)
   Frecuencia de pérdida = Probabilidad de agresión x probabilidad de éxito

Exposición anual de pérdidas (ALE) = Pérdida potencial ($) x Frecuencia

2. Tabla de evaluación financiera y exposición anual de pérdida (ALE)

Escala de Frecuencia / Probabilidad

- Baja (0,1 / año): Ocurrencia estimada de 1 vez cada 10 años.
- Media (0,5 / año): Ocurrencia estimada de 1 vez cada 2 años.
- Alta (1,0 / año): Ocurrencia estimada de 1 o más veces al año.

Escala de Impacto Monetario (I)

- Bajo: Mensor a 200.000 (pérdida operativa menor o equipamiento individual).
- Medio: De 200.000 a $1.000.000$ (afectación parcial de servicios o reingreso manual de datos).
- Alto: Superior a $1.000.000$ (paralización de certificaciones de obra, juicios o secuestro masivo de datos).

Activo	Amenaza	Prob. Agr.	Prob. Ex.	Frec. Pérd.	Pérd. Pot. ($)	Pérd. Esp. ($)
ERP Vial / BD Certificaciones	Ransomware	60%	75%	45%	$ 25.000.000	$ 11.250.000
ERP Vial / Fondo Vial	Hacking / Fraude	35%	50%	17.5%	$ 40.000.000	$ 7.000.000
SIG GeoVial	Virus / Corrupción	40%	45%	18.0%	$ 12.000.000	$ 2.160.000
Tablets SiCC Móvil	Hurto en Campo	65%	60%	39.0%	$ 4.500.000	$ 1.755.000
Red VPN Delegaciones	Caída / Interceptación	50%	40%	20.0%	$ 8.000.000	$ 1.600.000
Estaciones de Trabajo	Phishing Credenciales	70%	50%	35.0%	$ 6.000.000	$ 2.100.000
TOTALES ESTIMADOS	-	-	-	-	$ 95.500.000	$ 25.865.000

RECOMENDACIONES DE LA NORMA IRAM-ISO/IEC 27001 Y SU APLICACIÓN EN LA PROPUESTA

La norma IRAM-ISO/IEC 27001 establece los requisitos para un Sistema de Gestión de la Seguridad de la Información (SGSI) basado en la mejora continua (Ciclo PHVA: Planificar, Hacer, Verificar, Actuar).

A continuación se detalla en qué aspectos específicos de la propuesta DVP se aplican sus DOMINIOS Y CONTROLES ISO/IEC 27001 / 27002

Dominio ISO 27001 / 27002	**Aspecto Específico Aplicado en la Propuesta DVP (TP-2)**
A.5 Políticas de Seguridad	Elaboración de la Política General de Seguridad de la DVP y normas específicas sobre uso de VPN y tablets SiCC Móvil.
A.6 Organización de la Seguridad	Creación de la División Ciberseguridad en el nuevo organigrama dentro del Dpto. de Infraestructura y Telecomunicaciones.
A.7 Seguridad en Recursos Humanos	Inclusión de cláusulas de confidencialidad (NDA) e inducción obligatoria en ciberseguridad en la DyAC del Director de TICs
A.9 Control de Acceso	Autenticación basada en roles (RBAC) para el ERP Vial y gestión del Fondo Vial con cierre automático de sesión
A.10 Criptografía	Cifrado de túneles VPN (IPsec/TLS) con las 5 Delegaciones Zonales y cifrado de datos sensibles en PostgreSQL.
A.11 Seguridad Física y Entorno	Contratación de infraestructura IaaS en ECOM Chaco con Data Center certificado (control biométrico, climatización, UPS)
A.12/13 Seguridad Operacional y Comunicaciones	Separación de entornos de Desarrollo y Producción; registro de logs de auditoría para trazabilidad de certificaciones
A.15 Relación con Proveedores	Acuerdo de Nivel de Servicio (SLA con Uptime 99.5%) y derecho a auditoría en el contrato de IaaS con ECOM Chaco
A.17 Continuidad del Negocio	Formulación e institucionalización del Plan de Contingencia (DRP) con RPO de 12 horas y RTO de 4 horas.

1. **Políticas de Seguridad de la Información (A.5):**

- *Aplicación*: Se formula la Política General de Seguridad de la DVP, complementada con políticas específicas sobre el control de accesos al ERP Vial, la protección de coordenadas geográficas en el GeoVial y las normas de uso de dispositivos móviles (SiCC) en los campamentos viales.

2. **Organización de la Seguridad de la Información (A.6):**

- *Aplicación*: En el nuevo organigrama de la Dirección de TICs, se establece formalmente la División Servidores y Ciberseguridad dentro del *Departamento de Infraestructura y Telecomunicaciones*[1]. Esto segrega la función de desarrollo de software de la función de administración de infraestructura y seguridad, evitando conflictos de interés.

3. **Seguridad de los Recursos Humanos (A.7):**

- *Aplicación*: Se incorporan acuerdos de confidencialidad (NDA) e ingeniería de perfiles por competencias en la Descripción y Análisis de Cargos (DyAC) del Director de TICs y del personal técnico. Se incluyen capacitaciones obligatorias en ciberseguridad dentro del programa de inducción.

4. **Control de Acceso (A.9)**:

- *Aplicación*: Implementación de control de acceso basado en roles (RBAC) dentro del ERP Vial. Un inspector de obra solo puede registrar avances físicos de su zona; la aprobación financiera final del Fondo Vial queda reservada a las autoridades superiores. Cierre de sesiones por inactividad y autenticación obligatoria para el acceso VPN desde las 5 Delegaciones Zonale.

5. **Criptografía (A.10):**

- *Aplicación*: Cifrado de datos en tránsito utilizando protocolos seguros (TLS/HTTPS) para el acceso al GeoVial y túneles VPN IPsec cifrados para la comunicación entre las Delegaciones Zonales y la base de datos centra. Cifrado de campos sensibles (claves y datos financieros) dentro de PostgreSQL.

6. **Seguridad Física y del Entorno (A.11):**

- *Aplicación*: Al contratar la infraestructura como servicio (IaaS) en ECOM Chaco, se delega la protección física de los servidores críticos a un entorno controlado con seguridad biométrica, climatización de precisión, redundancia eléctrica (UPS y generadores) y sistemas automatizados de detección/extinción de incendios.

7. **Seguridad de las Operaciones y Comunicaciones (A.12 / A.13)**:

- *Aplicación*: Separación estricta de entornos de Desarrollo, Pruebas y Producción para el ERP Vial In-House. Registro automatizado de *logs* (pistas de auditoría) de todas las transacciones sobre certificaciones de obra para garantizar la trazabilida].

8. **Relaciones con Proveedores (A.15)**:

- *Aplicación*: El contrato marco de tercerización con ECOM Chaco incluye formalmente un acuerdo de nivel de servicio (SLA), acuerdos de confidencialidad, derecho a auditoría por parte del Control Interno Informático de la DVP y penalizaciones económicas automáticas ante incumplimientos de Uptime.

9. **Gestión de Incidentes de Seguridad de la Información (A.16):**

- *Aplicación*: Creación del procedimiento operativo estándar para la detección, reporte, escalado y contención de incidentes de seguridad a cargo de la División Ciberseguridad.

10. **Aspectos de Seguridad de la Información para la Gestión de la Continuidad del Negocio (A.17)**:

- *Aplicación*: Institucionalización del Plan de Contingencia y Recuperación ante Desastres (DRP) en las políticas de la DVP, garantizando las metas de RPO de 12 horas y RTO de 4 horas mediante respaldos *off-site* y esquemas de conmutación.

11. Cumplimiento (A.18):

- *Aplicación*: Auditorías periódicas de cumplimiento normativo legal e interno llevadas a cabo por el área de Auditoría de SI/TI, asegurando que los sistemas respeten las reglamentaciones provinciales de obras públicas y la ley de protección de datos.

Fase III: Manejo de Riesgos

3.1. Criterio metodológico adoptado

Una vez cuantificada la **Pérdida Esperada (ALE)** de cada par activo–amenaza en la Fase II, la Fase III define **qué se hace con cada riesgo**. El tratamiento se estructura en cuatro decisiones encadenadas:

1. **Estrategia genérica de manejo del riesgo:** Prevenir, Reducir, Transferir o Asumir.
2. **Controles o contramedidas** concretas, clasificadas según:
   - su **naturaleza**: control **físico** (actúa sobre el entorno y el equipamiento) o **lógico** (actúa sobre datos, software y redes);
   - su **alcance**: control **general** (protege a todo el ambiente de SI/TI) o **de aplicación** (específico de un sistema o proceso, p. ej. la validación de una certificación de obra en el ERP).
3. **Identificación de las intenciones**, ubicando cada contramedida en la línea de defensa que le corresponde: **1° Prevención**, **2° Detección**, **3° Recuperación**.
4. **Políticas de seguridad** asociadas, clasificadas en **prohibitivas**, **obligatorias** y **permisivas**.

Criterio de decisión de la estrategia genérica. Se adoptó una regla explícita en función de la Pérdida Esperada anual calculada en la Fase II, para que la elección no resulte arbitraria:

Nivel de riesgo	Pérdida Esperada anual (ALE)	Estrategia genérica adoptada
Crítico	Mayor a $ 7.000.000	Reducir + Transferir (control reforzado y cobertura contractual/seguro)
Alto	Entre $ 2.000.000 y $ 7.000.000	Reducir

Moderado	Entre $ 1.000.000 y $ 2.000.000	Reducir o Transferir según costo del control
Bajo	Menor a $ 1.000.000	Prevenir y asumir el riesgo residual

Criterio económico. Siguiendo el principio de que *el costo del control no debe superar a la pérdida que evita*, cada contramedida se dimensionó de modo tal que la suma de la inversión anual más la pérdida esperada residual resulte inferior a la pérdida esperada original (ver cuadro de costo-beneficio en el punto 3.10).

Decisión del grupo respecto de las políticas. Las políticas de seguridad se definen **por amenaza** (específicas para cada par activo–amenaza) y se consolidan luego en una **Política General de Seguridad de la Información de la DVP** (punto 3.9), que es el documento que se eleva para su aprobación por resolución del Administrador General. De este modo se cubren ambos enfoques: el operativo y el institucional.

3.2. Activo: Base de Datos PostgreSQL del ERP Vial — Módulo Certificaciones de Obra

- **Amenaza:** Ransomware / Malware de cifrado.
- **Pérdida esperada (Fase II):** $ 11.250.000 — **riesgo crítico** (el mayor del inventario).
- **Estrategia genérica: Reducir + Transferir.** Se reduce con controles técnicos y de respaldo, y se transfiere parcialmente mediante el SLA con ECOM Chaco y la póliza de ciberriesgo.

Controles y contramedidas

Contramedida	Naturaleza	Alcance
Solución EDR/Antimalware centralizada con consola de administración en la División Ciberseguridad	Lógico	General
Esquema de respaldo 3-2-1 con **copia inmutable** *off-site* (no sobrescribible ni borrable durante 30 días)	Lógico	General
Segmentación de la red: VLAN separada para servidores de base de datos, sin acceso directo desde estaciones administrativas	Lógico	General

Bloqueo de ejecución de macros y de ejecutables no firmados en estaciones de trabajo (*whitelisting*)	Lógico	General
Firma y trazabilidad de cada certificación de obra en el ERP (log inalterable de alta, modificación y aprobación)	Lógico	De aplicación
Póliza de ciberriesgo y cláusula de responsabilidad del proveedor IaaS	Legal / Contractual	Transferencia

Identificación de las intenciones (líneas de defensa)

- **1° Prevención:** EDR actualizado en todos los servidores y estaciones; aplicación mensual de parches de seguridad del sistema operativo y de PostgreSQL; segmentación de red y principio de mínimo privilegio; bloqueo de dispositivos USB no autorizados; capacitación obligatoria del personal administrativo.
- **2° Detección:** Monitoreo de logs de PostgreSQL y alertas automáticas ante volúmenes anómalos de escritura o cifrado masivo de archivos; alerta ante accesos fuera del horario 07:00–14:00; verificación automática diaria de la integridad del backup.
- **3° Recuperación:** Aislamiento inmediato del segmento afectado; restauración de la última copia íntegra desde el repositorio inmutable (RPO comprometido: 12 horas); reconstrucción del período no respaldado a partir de las actas de medición en papel; denuncia ante el CERT.ar y la fiscalía competente; informe de auditoría posterior.

Políticas de seguridad

- **Permisiva:** Está prohibido desactivar el antimalware, el firewall o el cifrado en cualquier equipo de la DVP sin autorización expresa de la División Ciberseguridad.
- **Permisiva:** Está prohibida la conexión de dispositivos de almacenamiento extraíbles personales a equipos de la red administrativa.
- **Permisiva: Está estrictamente prohibido** almacenar o dar por válidas las copias de respaldo de la base de datos sin haber ejecutado y documentado en acta su correspondiente prueba mensual de restauración.
- **Prohibitiva: Sólo se permite** la conexión y operación en la red de servidores y estaciones de trabajo que cuenten con el antimalware activo y un sistema operativo con soporte y parches vigentes.

- **Prohibitiva:** Sólo se permite el acceso remoto y la administración de la base de datos PostgreSQL a través de la VPN institucional con doble factor de autenticación (2FA) activo

3.3. Activo: ERP Vial — Módulo de gestión del Fondo Vial

- **Amenaza:** Hacking / Fraude interno sobre órdenes de pago y expedientes de fondos.
- **Pérdida esperada (Fase II):** $ 7.000.000 — **riesgo crítico**.
- **Estrategia genérica: Reducir.** Es un riesgo que no puede transferirse: el daño principal es patrimonial y reputacional sobre fondos públicos y su responsabilidad es indelegable.

Controles y contramedidas

Contramedida	**Naturaleza**	**Alcance**
Control de acceso basado en roles (RBAC) con perfiles diferenciados: carga, supervisión y autorización	Lógico	De aplicación
Segregación de funciones: quien carga una orden de pago no puede autorizarla	Lógico	De aplicación
Doble factor de autenticación (2FA) obligatorio para los perfiles contables y de autorización	Lógico	De aplicación
Pista de auditoría inalterable (usuario, fecha, hora, terminal e IP de cada operación)	Lógico	De aplicación
Restricción de acceso por rango de direcciones IP institucionales y cierre automático de sesión por inactividad	Lógico	General
Auditoría trimestral de permisos y baja inmediata de usuarios desvinculados	Lógico	General

Identificación de las intenciones

- **1° Prevención:** RBAC y segregación de funciones configuradas en el propio ERP; 2FA; acuerdos de confidencialidad (NDA) firmados por el personal con acceso al módulo; topes de monto por perfil que exigen autorización superior.
- **2° Detección:** Revisión automática de transacciones fuera de parámetro (montos atípicos, cargas fuera de horario, modificaciones posteriores a la

aprobación); conciliación mensual entre el ERP y los registros de Contaduría; alertas por intentos fallidos de autenticación reiterados.

- **3° Recuperación:** Bloqueo inmediato de las credenciales comprometidas; reversión de las transacciones observadas a partir de la pista de auditoría; sumario administrativo y denuncia penal si correspondiere; restauración del estado consistente de la base a partir del *point-in-time recovery*.

Políticas de seguridad

- **Permisiva:** Está prohibido compartir credenciales de acceso al ERP entre agentes, bajo cualquier circunstancia y aun entre pares del mismo sector.
- **Permisiva:** Ningún agente puede cargar y autorizar la misma orden de pago.
- **Prohibitiva: Sólo se permite** el inicio de sesión y la tramitación de pagos en el ERP a aquellos usuarios que validen su identidad mediante doble factor de autenticación (2FA). .
- **Prohibitiva: Únicamente se autoriza** tramitar altas, bajas o cambios de permisos en los sistemas institucionales si cuentan con el respaldo de una nota formal presentada por la jefatura del área solicitante ante la Dirección de TICs.
- **Prohibitiva:** Sólo se permite la consulta de expedientes del Fondo Vial en modo de sólo lectura a los agentes de las Delegaciones Zonales que se encuentren formalmente autorizados.

3.4. Activo: SIG GeoVial (capas cartográficas y avance de obra)

- **Amenaza:** Virus / Corrupción de datos espaciales.
- **Pérdida esperada (Fase II):** $ 2.160.000 — **riesgo alto**.
- **Estrategia genérica: Reducir.**

Controles y contramedidas

Contramedida	**Naturaleza**	**Alcance**
Separación estricta de los entornos de Desarrollo, Prueba y Producción	Lógico	General
Versionado de las capas geográficas con posibilidad de retorno a versión anterior	Lógico	De aplicación

Validación de integridad (*checksum*) de las capas al momento de la publicación	Lógico	De aplicación
Antimalware en los puestos de los técnicos de Ingeniería que editan cartografía	Lógico	General
Respaldo diario diferencial y semanal completo del repositorio espacial	Lógico	General

Identificación de las intenciones

- **1° Prevención:** Ningún cambio pasa a Producción sin pruebas previas en el entorno de Testing; permisos de edición cartográfica limitados a los técnicos habilitados del Departamento de Sistemas y Desarrollo; antimalware activo.
- **2° Detección:** Verificación automática de *checksum* y control de consistencia topológica al publicar; alerta ante modificaciones masivas de capas; revisión mensual del registro de publicaciones.
- **3° Recuperación:** Retorno a la versión anterior de la capa afectada (*rollback*); restauración desde el respaldo diario; reprocesamiento de los relevamientos desde los archivos originales de campo.

Políticas de seguridad

- **Permisiva:** Está prohibido instalar software no autorizado por la Dirección de TICs en los equipos que operan el SIG.
- **Permisiva:** Está prohibido publicar en Producción capas que no hayan sido validadas en el entorno de prueba.
- **Prohibitiva: Sólo se permite** la publicación y despliegue de capas cartográficas en los servidores del SIG cuando el sistema genere automáticamente el registro de auditoría con identificación de usuario, fecha y detalle del cambio.
- **Prohibitiva:** Sólo se permite la descarga de capas cartográficas en formato de sólo lectura a los inspectores de obra para su utilización operativa en campo.

3.5. Activo: Tablets con SiCC Móvil (despacho de combustible en campamentos viales)

- **Amenaza:** Hurto o robo del dispositivo en campo.
- **Pérdida esperada (Fase II):** $ 1.755.000 — **riesgo moderado**.

- **Estrategia genérica: Transferir + Reducir.** El costo del equipamiento se transfiere mediante póliza de seguro técnico; el valor de la información residente se reduce con controles lógicos.

Controles y contramedidas

Contramedida	Naturaleza	Alcance
Póliza de seguro técnico con cobertura de robo y hurto en tránsito y en campamento	Organizacional	Transferencia
Inventario patrimonial serializado y acta de asignación individual firmada por el inspector	Físico	General
Plataforma de administración de dispositivos móviles (MDM) con geolocalización y borrado remoto	Lógico	General
Bloqueo por PIN/biometría y cifrado del almacenamiento del dispositivo	Lógico	General
Carcasas reforzadas, cable de seguridad y guarda en gabinete bajo llave en el campamento	Físico	General
Sincronización en línea de los despachos: el dato reside en el servidor, no en la tablet	Lógico	De aplicación

Identificación de las intenciones

- **1° Prevención:** Acta de entrega con responsabilidad patrimonial del agente; capacitación sobre resguardo del equipo; PIN/biometría y cifrado obligatorios; almacenamiento mínimo de datos en el dispositivo.
- **2° Detección:** Geolocalización permanente por MDM; auditoría mensual de inventario en las 5 Delegaciones Zonales; alerta automática ante dispositivos que no sincronizan por más de 72 horas.
- **3° Recuperación:** Borrado remoto (*remote wipe*) y bloqueo del dispositivo; denuncia policial y comunicación a la aseguradora; reposición desde el stock de reserva (10 % del parque); revocación de las credenciales asociadas al equipo.

Políticas de seguridad

- **Permisiva:** Está prohibido el uso personal de las tablets institucionales y la instalación de aplicaciones ajenas al SiCC Móvil.
- **Permisiva:** Está prohibido dejar el dispositivo en vehículos o fuera del gabinete asignado al finalizar la jornada.
- **Prohibitiva: Sólo se permite** la entrega y uso operativo de las tablets institucionales si estas se encuentran enroladas en la plataforma MDM y disponen de mecanismo de bloqueo por PIN o biometría activo.
- **Obligatoria:** La pérdida o el hurto debe denunciarse dentro de las 24 horas al Departamento de Soporte y Atención al Usuario.
- **Prohibitiva:** Sólo se permite la operación sin conexión del SiCC Móvil en campamentos viales o zonas aisladas que carezcan transitoriamente de señal, resultando mandatoria su sincronización al recuperar conectividad.

3.6. Activo: Red VPN de las Delegaciones Zonales

- **Amenaza:** Caída del enlace / Interceptación de datos en tránsito.
- **Pérdida esperada (Fase II):** $ 1.600.000 — **riesgo moderado**.
- **Estrategia genérica: Reducir + Transferir** (la disponibilidad del enlace se transfiere contractualmente al proveedor mediante SLA).

Controles y contramedidas

Contramedida	**Naturaleza**	**Alcance**
Túneles VPN cifrados con IPsec/TLS entre Sede Central y las 5 Delegaciones	Lógico	General
Enlace de respaldo 4G/5G con conmutación automática ante caída del enlace principal	Físico	General
SLA con el proveedor de conectividad, con disponibilidad comprometida y penalidades	—	Transferencia
Certificados digitales por equipo (no sólo usuario y contraseña) para establecer el túnel	Lógico	General
Monitoreo permanente de disponibilidad de enlaces con tablero en la Mesa de Ayuda	Lógico	General

Identificación de las intenciones

- **1° Prevención:** Cifrado de extremo a extremo de todo el tráfico entre delegaciones y Sede Central; autenticación por certificado de equipo; prohibición de acceso al ERP desde redes públicas sin VPN.
- **2° Detección:** Monitoreo continuo con alertas por caída de enlace superior a 15 minutos; revisión de los registros de conexión VPN en busca de accesos desde ubicaciones o equipos no habilitados.
- **3° Recuperación:** Conmutación al enlace de respaldo 4G/5G; operación en modo degradado con formularios en papel en la delegación afectada; reclamo formal al proveedor y aplicación de penalidades del SLA.

Políticas de seguridad

- **Prohibitiva:** Sólo se permite el acceso a los sistemas informáticos de la DVP desde redes externas o públicas mediante el uso ineludible de la VPN institucional activa con doble factor de autenticación (2FA).
- **Prohibitiva:** Sólo se permite la conexión a la red corporativa de las delegaciones zonales a equipamiento informático oficial, debidamente homologado e inventariado como propiedad de la DVP.
- **Prohibitiva: Sólo se permite** cursar tráfico de datos institucional entre las Delegaciones Zonales y la Sede Central a través de canales de comunicación cifrados (túneles IPsec / TLS).
- **Prohibitiva:** Sólo se permite la modalidad de teletrabajo a aquellos agentes debidamente autorizados y conectándose exclusivamente a través de la VPN corporativa con doble factor de autenticación.

3.7. Activo: Estaciones de trabajo administrativas y credenciales de los agentes

- **Amenaza:** Phishing dirigido para sustracción de credenciales.
- **Pérdida esperada (Fase II):** $ 2.100.000 — **riesgo alto**.
- **Estrategia genérica: Reducir.** El vector de ataque es humano, por lo que el control principal es la capacitación.

Controles y contramedidas

Contramedida	Naturaleza	Alcance
Programa anual de concientización en ciberseguridad con asistencia obligatoria	—	General (control administrativo)
Campañas periódicas de phishing simulado con medición de la tasa de clic	Lógico	General
Filtro antispam y de reputación de remitentes en el correo institucional	Lógico	General
Bandera visible de "correo externo" en todo mensaje proveniente de fuera del dominio	Lógico	General
Doble factor de autenticación en correo y en el acceso al ERP	Lógico	General
Gestor de contraseñas institucional y política de complejidad y caducidad	Lógico	General

Identificación de las intenciones

- **1° Prevención:** Capacitación obligatoria al ingreso y actualización anual; 2FA; gestor de contraseñas; filtro antispam; bloqueo de dominios de dudosa reputación.
- **2° Detección:** Alerta ante tres intentos fallidos consecutivos de autenticación; detección de inicios de sesión desde ubicaciones inusuales; canal interno de denuncia de correos sospechosos a la Mesa de Ayuda; medición de la tasa de clic en las campañas simuladas.
- **3° Recuperación:** Cambio forzado de la credencial comprometida y de todas las asociadas; cierre de las sesiones activas; revisión de las operaciones realizadas con esa cuenta durante el período comprometido; comunicación institucional de alerta a todo el personal.

Políticas de seguridad

- **Permisiva:** Está prohibido enviar credenciales de acceso por correo electrónico, mensajería o cualquier otro medio.
- **Permisiva:** Está prohibido abrir archivos adjuntos o enlaces no solicitados provenientes de remitentes externos.

- **Permisiva: Está prohibido** responder, reenviar o ejecutar enlaces y archivos adjuntos de correos electrónicos sospechosos sin la previa verificación e intervención de la Mesa de Ayuda de TICs.
- **Prohibitiva: Sólo se permite** la emisión y recepción de comunicaciones laborales y notificaciones administrativas oficiales a través de casillas de correo bajo el dominio oficial de la DVP.
- **Prohibitiva:** Sólo se permite el acceso y uso del correo institucional desde dispositivos móviles si estos disponen de mecanismo de bloqueo de pantalla activo y autenticación de doble factor (2FA).

3.8. Activo: Instalaciones de Sede Central y Delegaciones Zonales

- **Amenaza:** Incendio, inundación o corte prolongado de energía (única amenaza física accidental cuantificada).
- **Pérdida esperada (Fase II):** $ 900.000 — **riesgo bajo**, atenuado por el alojamiento de los servidores productivos en el Data Center del proveedor.
- **Estrategia genérica: Prevenir + Transferir.**

Controles y contramedidas

Contramedida	**Naturaleza**	**Alcance**
Detectores de humo, matafuegos clase C y señalización de evacuación	Físico	General
UPS en el rack de comunicaciones y grupo electrógeno con autonomía de 8 horas	Físico	General
Traslado de los servidores productivos al Data Center certificado de ECOM Chaco (IaaS)	Físico	General
Elevación del tablero eléctrico y del rack sobre el nivel de piso (riesgo hídrico)	Físico	General
Seguro técnico sobre equipamiento e instalaciones	—	Transferencia

Identificación de las intenciones

- **1° Prevención:** Revisión semestral de la instalación eléctrica; prohibición de fumar en áreas técnicas; mantenimiento preventivo de UPS y grupo electrógeno; no alojar servidores productivos en la Sede Central.
- **2° Detección:** Detectores de humo y sensores de temperatura en el rack con alerta a la Mesa de Ayuda; monitoreo del estado de la UPS.
- **3° Recuperación:** Evacuación conforme al protocolo de Seguridad e Higiene; operación desde el sitio alternativo; reposición de equipamiento con cargo a la póliza; restauración de servicios desde el IaaS, que permanece indemne.

Políticas de seguridad

- **Permisiva:** está prohibido fumar y almacenar materiales inflamables en las oficinas técnicas y en el área del rack.
- **Permisiva: Está estrictamente prohibido** superar el lapso de un año calendario sin haber llevado a cabo y registrado formalmente el simulacro de evacuación y el ensayo operativo del grupo electrógeno.
- **Prohibitiva:** Sólo se permite el ingreso y permanencia en el recinto del rack de comunicaciones al personal técnico de Infraestructura y Telecomunicaciones, requiriéndose su registro formal en planilla de acceso.

3.9. Política General de Seguridad de la Información de la DVP

Las políticas específicas definidas por amenaza se consolidan en un documento marco, a aprobarse por resolución del Administrador General y de cumplimiento obligatorio para todo el personal, incluidos contratados y terceros (control **A.5 — Políticas de Seguridad de la Información**).

1. Políticas Prohibitivas (Enunciación de lo expresamente AUTORIZADO)

- **1.1. Uso de Credenciales:** Las credenciales de acceso (usuario y contraseña) son estrictamente personales, intransferibles y de uso exclusivo por parte del agente titular asignado.

- **1.2. Conexión de Equipamiento:** La conexión a la red corporativa de la Sede Central y Delegaciones Zonales está permitida exclusivamente a dispositivos informáticos oficiales, homologados y registrados como propiedad de la DVP.
- **1.3. Controles de Seguridad Activos:** Los componentes de protección (antimalware, firewall local y cifrado) deben permanecer activos e ininterrumpidos en todo el equipamiento, autorizándose su modificación o desactivación únicamente a la División Ciberseguridad.
- **1.4. Software Autorizado:** Está permitida exclusivamente la instalación y ejecución de software homologado y provisto por la Dirección de TICs en los puestos de trabajo institucionales.
- **1.5. Dispositivos Móviles (SiCC Móvil):** El uso de las tablets corporativas asignadas al SiCC Móvil está autorizado únicamente para la ejecución de tareas operativas y oficiales del organismo.
- **1.6. Medios Removibles:** La extracción o transporte de información institucional mediante dispositivos almacenamiento removible está autorizada exclusivamente en medios cifrados y homologados por la Dirección de TICs.
- **1.7. Acceso Remoto y Teletrabajo:** El acceso a los sistemas de la DVP desde fuera de la red corporativa está autorizado únicamente mediante el uso de la VPN institucional con doble factor de autenticación (2FA) activo.
- **1.8. Consulta de Expedientes:** La consulta de expedientes por parte de las Delegaciones Zonales está habilitada exclusivamente en modo lectura y para los usuarios o dependencias expresamente autorizados.
- **1.9. Operación Fuera de Línea:** La operación sin conexión del sistema SiCC Móvil está autorizada únicamente en campamentos o zonas rurales aisladas, siendo obligatoria su sincronización inmediata al restablecer la conectividad.
- **2.1. Autenticación Reforzada: Sólo se permite** el acceso a los sistemas informáticos que administren o procesen fondos públicos (ERP Vial / Fondo Vial) mediante el uso ineludible de doble factor de autenticación (2FA).
- **2.2. Cifrado de Comunicaciones: Sólo se permite** la transmisión de datos web a través de protocolos seguros HTTPS/TLS y la interconexión con delegaciones zonales mediante túneles IPsec.
- **2.3. Compromisos de Confidencialidad: Sólo se permite** la habilitación de accesos a sistemas e información institucional a agentes o contratados que hayan suscripto el correspondiente Acuerdo de Confidencialidad (NDA).

2. Políticas Permisivas (Enunciación de lo expresamente PROHIBIDO)

- **2.4. Capacitación y Concientización: Está prohibido** que el personal de la DVP opere sistemas informáticos institucionales sin registrar la asistencia y aprobación anual del programa de capacitación en ciberseguridad.
- **2.5. Gestión de Respaldos: Está prohibido** apartarse del esquema de copias 3-2-1 o prescindir de la prueba mensual documentada de restauración de datos.
- **2.6. Gestión de Incidentes: Está estrictamente prohibido** omitir, encubrir o demorar el reporte inmediato de cualquier incidente, anomalía o sospecha de brecha de seguridad ante la Mesa de Ayuda de TICs.

3.10. Evaluación costo-beneficio de las contramedidas propuestas

Se verifica que la inversión anual en seguridad resulte inferior al beneficio obtenido por la reducción de la pérdida esperada. Los valores de inversión son estimaciones a valores del ejercicio y los de pérdida residual surgen de recalcular la frecuencia de pérdida con la probabilidad de éxito de la agresión disminuida por efecto de los controles.

Activo / Amenaza	**Pérdida Esperada actual**	**Inversión anual estimada**	**Pérdida Esperada residual**	**Beneficio neto**
BD Certificaciones / Ransomware	$ 11.250.000	$ 3.500.000	$ 3.750.000	$ 4.000.000
Fondo Vial / Hacking-Fraude	$ 7.000.000	$ 2.200.000	$ 2.800.000	$ 2.000.000
SIG GeoVial / Virus	$ 2.160.000	$ 900.000	$ 960.000	$ 300.000
Tablets SiCC / Hurto	$ 1.755.000	$ 700.000	$ 700.000	$ 355.000
Red VPN / Caída-Interceptación	$ 1.600.000	$ 1.100.000	$ 640.000	($ 140.000)
Estaciones / Phishing	$ 2.100.000	$ 600.000	$ 840.000	$ 660.000
Instalaciones / Incendio-energía	$ 900.000	$ 500.000	$ 300.000	$ 100.000

TOTALES	**$ 26.765.000**	**$ 9.500.000**	**$ 9.990.000**	**$ 7.275.000**

Lectura del cuadro. La exposición anual de pérdida se reduce de $ 26.765.000 a $ 9.990.000, con una inversión anual de $ 9.500.000: el beneficio neto para la DVP asciende a **$ 7.275.000 anuales**, además de los beneficios no monetizados (continuidad del servicio a las delegaciones, cumplimiento normativo y confianza pública en la gestión del Fondo Vial).

El único caso en que la inversión se aproxima al beneficio directo es el de la **red VPN**, donde el enlace redundante tiene un costo mensual significativo frente a una pérdida esperada moderada. Se sostiene igualmente la inversión porque la conectividad es **condición previa** para que operen todos los demás controles y para cumplir los tiempos de recuperación comprometidos en la Fase IV: su justificación es de disponibilidad, no de costo evitado.

3.11. Aplicación de la norma IRAM-ISO/IEC 27001 en la Fase III

Dominio / Control	**Aplicación concreta en la propuesta de la DVP**
A.5 Políticas de Seguridad	Política General de Seguridad de la DVP (punto 3.9), aprobada por resolución y difundida a todo el personal.
A.6 Organización de la Seguridad	Creación de la **División Ciberseguridad** dentro del Dpto. de Infraestructura y Telecomunicaciones del nuevo organigrama (TP-2, punto 1.A).
A.7 Seguridad en los RRHH	NDA obligatorio, capacitación anual, e inclusión de la competencia “Manejo de Crisis” en la DyAC del Director de TICs (TP-2, punto 1.B).
A.8 Gestión de Activos	Inventario patrimonial serializado de tablets y estaciones, con acta de asignación individual.
A.9 Control de Acceso	RBAC y segregación de funciones en el ERP; 2FA en perfiles contables; cierre automático de sesión; baja inmediata de usuarios desvinculados.
A.10 Criptografía	Cifrado IPsec/TLS de los túneles VPN con las 5 delegaciones y cifrado del almacenamiento de las tablets.
A.11 Seguridad Física y del Entorno	Data Center certificado de ECOM Chaco; UPS y grupo electrógeno; control de acceso al rack; detección de incendio.

A.12 Seguridad Operacional	Antimalware, gestión de parches, esquema de respaldo 3-2-1 con copia inmutable y prueba de restauración mensual.
A.13 Seguridad de las Comunicaciones	Segmentación en VLAN, filtro antispam y prohibición de BYOD en la red corporativa.
A.14 Adquisición y Desarrollo	Separación de entornos Desarrollo / Prueba / Producción en el desarrollo In-House del ERP y GeoVial.
A.15 Relación con Proveedores	SLA del 99,5 % con ECOM Chaco, cláusula de derecho a auditoría y penalidades por incumplimiento.
A.16 Gestión de Incidentes	Canal de reporte a la Mesa de Ayuda, registro de incidentes y comunicación al CERT.ar.

Fase IV: Plan de Contingencia y Recuperación ante Desastres

Desarrollado conforme a los lineamientos del artículo "Plan B: Estrategias de Contingencia" y a la metodología de Lardent.

4.1. Introducción

El presente Plan de Contingencia y Recuperación ante Desastres (DRP) tiene por objeto **garantizar la continuidad de los servicios esenciales de la Dirección de Vialidad Provincial del Chaco** ante la materialización de las amenazas identificadas en la Fase I, con especial atención a la certificación de obras, la administración del Fondo Vial y el despacho de combustible en los campamentos viales.

El plan será distribuido, en su versión impresa y digital, a los titulares de la Dirección de TICs, de las Direcciones de Construcciones, Ingeniería y Administración, y a los jefes de las 5 Delegaciones Zonales. **Debe ejecutarse un simulacro completo por semestre** y revisarse ante todo cambio significativo de la infraestructura.

El documento se organiza en las siguientes secciones: definición del desastre, supuestos, exclusiones, inventarios y niveles de operatividad, responsables y roles, prioridades de recuperación, orden de procesamiento, disponibilidad de hardware e instalaciones alternativas, alarma, procedimiento de recuperación, logística, mantenimiento y puesta a prueba, y apéndices.

4.2. Definición del desastre y niveles de gravedad

Se entiende por **desastre informático** todo evento que produzca la pérdida total o parcial de la capacidad de la DVP para certificar obras, administrar el Fondo Vial o abastecer de combustible a sus campamentos, comprometiendo el cumplimiento de plazos administrativos y la ejecución del plan de obras provincial.

Las amenazas identificadas se clasifican en cinco niveles de gravedad, cada uno con la estrategia genérica que le corresponde:

Nivel	Denominación	Eventos de la DVP comprendidos	Estrategia genérica
1	**Inconveniente**	Lentitud puntual del SIG GeoVial; falla de una impresora; falla aislada de una tablet.	Asumir
2	**Interrupción moderada**	Hurto de una o dos tablets SiCC; caída de la VPN de una delegación por menos de 4 horas; falla de una estación de trabajo.	Prevenir
3	**Evento significativo**	Malware contenido en un sector administrativo; corrupción de capas del GeoVial; caída de la VPN en varias delegaciones por más de 8 horas; corte de energía prolongado en Sede Central.	Reducir
4	**Desastre**	Ransomware sobre la BD PostgreSQL de certificaciones; fraude o hacking sobre el módulo de Fondo Vial; indisponibilidad del IaaS de ECOM Chaco por encima del RTO comprometido.	Reducir + Transferir
5	**Catástrofe**	Incendio o inundación de la Sede Central con pérdida de las instalaciones y de la conectividad; destrucción del Data Center del proveedor.	Transferir

Criterio de activación del plan: el DRP se activa a partir del **nivel 3**. Los niveles 1 y 2 se resuelven por los procedimientos ordinarios de la Mesa de Ayuda, sin convocar al Comité de Crisis.

4.3. Supuestos

El plan se elabora sobre la base de los siguientes supuestos, que deben mantenerse vigentes para que los tiempos comprometidos sean alcanzables:

1. Los servidores productivos del ERP Vial y del SIG GeoVial se encuentran alojados bajo modalidad **IaaS en el Data Center de ECOM Chaco**, con SLA del 99,5 %, RPO de 12 horas y RTO de 4 horas, y réplica en un segundo centro de datos del proveedor.
2. Existe un esquema de respaldo **3-2-1**: una copia en línea en el IaaS, una copia local en Sede Central y una copia inmutable *off-site*, con retención de 30 días.
3. La DVP dispone de un **sitio alternativo de trabajo** en el edificio de la Delegación Zonal Resistencia, con capacidad para 15 puestos, enlace de datos propio y energía respaldada.
4. Se mantiene un **stock de reserva** equivalente al 10 % del parque de tablets y 5 notebooks preconfiguradas en el depósito de la Dirección de TICs.
5. La Sede Central cuenta con **UPS y grupo electrógeno** con autonomía de 8 horas para el rack de comunicaciones y los puestos críticos.
6. Existe una **póliza de seguro técnico y de ciberriesgo** vigente sobre equipamiento e información.
7. Los procedimientos manuales sustitutivos —planilla de despacho de combustible y acta de medición de obra en papel— están **aprobados por Contaduría** y disponibles en cada delegación y campamento.
8. El personal de las áreas críticas recibió capacitación sobre el plan y participó del último simulacro semestral.

4.4. Exclusión de desastres

Quedan expresamente **fuera del alcance** de este plan, por exceder la capacidad de respuesta del organismo, los siguientes eventos:

- Conflicto armado, holocausto nuclear o atentado terrorista.
- Terremoto de gran magnitud que afecte simultáneamente a la Sede Central y al Data Center del proveedor.
- Colapso simultáneo de la red eléctrica provincial y de todos los proveedores de conectividad por más de 72 horas.
- Inundación de alcance regional que impida el acceso físico tanto a la Sede Central como al sitio alternativo.
- Hechos delictivos con toma de rehenes o que comprometan la integridad física del personal, cuya conducción corresponde a las fuerzas de seguridad.

Ante cualquiera de estos supuestos, la conducción de la emergencia queda a cargo de las autoridades provinciales competentes y el presente plan se limita a la protección de la vida humana y al resguardo de los respaldos de información.

4.5. Inventarios y niveles de operatividad

Inventario de software

- ERP Vial Integral (desarrollo In-House) — módulos Certificaciones, Fondo Vial, Compras y RRHH.
- SIG GeoVial (servidor de mapas y repositorio de capas).
- SiCC Móvil (aplicativo de despacho de combustible en campamentos).
- Motor de base de datos PostgreSQL.
- Suite de ofimática y correo institucional.
- Plataforma MDM de administración de dispositivos móviles.

Inventario de hardware y servicios

- Servidores virtuales IaaS en ECOM Chaco (producción y réplica).
- Rack de comunicaciones, firewall y concentrador VPN en Sede Central.
- Estaciones de trabajo de Sede Central y de las 5 Delegaciones Zonales.
- Tablets con SiCC Móvil asignadas a inspectores y campamentos.
- Enlaces de datos principales, enlaces de respaldo 4G/5G, UPS y grupo electrógeno.

Aplicaciones críticas: ERP Vial — módulos Certificaciones y Fondo Vial; SiCC Móvil; conectividad VPN.

Niveles de operatividad del servicio

Nivel	Descripción	Tiempo estimado de recuperación
Servicio interrumpido	Catástrofe: ninguna actividad puede realizarse en Sede Central; las delegaciones operan sólo en papel.	Hasta 3 días

Servicio parcialmente operativo	Desastre o evento significativo: parte de los sistemas está fuera de servicio, pero las funciones esenciales continúan en el sitio alternativo o en modo manual.	Hasta 24 horas
Servicio operativo con inconvenientes	Afectación menor que no compromete las actividades críticas.	Horas

4.6. Responsables y roles — Comité de Crisis

Rol en el plan	Cargo responsable	Responsabilidad durante la contingencia	Suplente
Coordinador General del Plan	Director de TICs	Declara formalmente la contingencia y su finalización; conduce el Comité; informa al Administrador General; autoriza el traslado al sitio alternativo.	Jefe Dpto. Infraestructura
Líder Técnico de Recuperación	Jefe Dpto. Infraestructura y Telecomunicaciones	Coordina la restauración de servidores, enlaces y respaldos; actúa como interlocutor técnico con ECOM Chaco.	Administrador de Servidores
Responsable de Seguridad	Jefe División Ciberseguridad	Contiene el incidente, preserva la evidencia, realiza el análisis forense y tramita la denuncia ante el CERT.ar.	Analista de Ciberseguridad
Responsable Funcional de Sistemas	Jefe Dpto. Sistemas y Desarrollo	Valida la integridad funcional del ERP y del GeoVial tras la restauración; dirige la conciliación de los datos procesados manualmente.	Analista Funcional del ERP

Responsable de Logística y Usuarios	Jefe Dpto. Soporte y Atención al Usuario	Provee equipamiento de reemplazo, habilita los puestos del sitio alternativo y comunica el estado a las delegaciones.	Referente de Mesa de Ayuda
Referente Zonal	Jefe de cada Delegación Zonal (5)	Activa los procedimientos manuales en su jurisdicción y eleva el parte diario de operación degradada.	Administrativo designado
Responsable Contable	Representante de la Dirección de Administración	Valida contablemente las certificaciones y despachos reprocesados; gestiona el reclamo ante la aseguradora.	Contador auxiliar
Responsable de Seguridad e Higiene	Referente del área	Conduce la evacuación y la protección de la vida humana; verifica las condiciones de reingreso al edificio.	Delegado de personal
Vocería institucional	Administrador General o quien éste designe	Única voz autorizada para comunicaciones públicas y a otros organismos.	—

Apoyo externo: mesa de crisis de ECOM Chaco (IaaS y enlaces), CERT.ar (incidentes de seguridad), aseguradora y proveedor de conectividad de respaldo.

4.7. Prioridades de recuperación de los sistemas

El orden de restablecimiento responde a la clasificación por tolerancia a la interrupción y a las dependencias técnicas entre sistemas:

Orden	Sistema / Servicio	Clasificación	Tolerancia	RTO	RPO

1	Conectividad, VPN, directorio de usuarios y firewall	Crítico (habilitante)	Nula	2 horas	—
2	Base de datos PostgreSQL + ERP módulos Certificaciones y Fondo Vial	Crítico	Muy baja	4 horas	12 horas
3	SiCC Móvil — despacho de combustible	Sensible	Moderada (opera en papel)	8 horas	24 horas
4	SIG GeoVial	Vital	Moderada	24 horas	24 horas
5	Correo institucional, ofimática y Mesa de Ayuda	Vital	Moderada	24 horas	24 horas
6	Tableros gerenciales, portal web y consultas históricas	No crítico	Alta	72 horas	72 horas

Fundamento del orden. La conectividad se restablece primero porque **ningún otro servicio puede operar sin ella**. Le sigue el ERP porque sus módulos de certificación y fondos están sujetos a **plazos administrativos perentorios**, cuyo incumplimiento genera intereses, observaciones del Tribunal de Cuentas y paralización de obras. El SiCC Móvil admite operación manual transitoria y el GeoVial, si bien es vital para la planificación, no compromete plazos legales en el corto plazo.

4.8. Orden de procesamiento de las tareas al reanudar la operación

Restablecidos los sistemas, el reprocesamiento de la información acumulada durante la contingencia se ejecuta en el siguiente orden, definido por criterio de **impacto legal y económico** y luego **operativo**:

1. **Certificaciones de obra con vencimiento de plazo** dentro de los 5 días hábiles siguientes (evita intereses y reclamos de las contratistas).
2. **Órdenes de pago y expedientes del Fondo Vial** pendientes de autorización, con conciliación previa contra los registros de Contaduría.
3. **Carga de los despachos de combustible** registrados en planilla papel durante la contingencia, con conciliación de existencias en cada campamento.
4. **Actualización de las capas del SIG GeoVial** y de los avances de obra relevados en campo.

5. **Altas y movimientos de personal** y demás trámites administrativos diferidos.
6. **Reportes gerenciales, tableros y consultas históricas**, una vez normalizada la operación transaccional.

Cada etapa concluye con un **acta de conciliación** firmada por el Responsable Funcional de Sistemas y el Responsable Contable, que deja constancia de los registros reprocesados y de las diferencias detectadas.

4.9. Disponibilidad de hardware e instalaciones alternativas

Recurso	Ubicación / Provisión	Modalidad	Disponibilidad comprometida
Sitio principal de procesamiento	Data Center de ECOM Chaco (IaaS)	Producción	99,5 % según SLA
Sitio alterno de procesamiento	Segundo centro de datos de ECOM Chaco	Réplica en caliente (*warm site*)	Conmutación dentro del RTO de 4 horas
Sitio alterno de trabajo	Edificio de la Delegación Zonal Resistencia	15 puestos, enlace propio y energía respaldada	Habilitado dentro de las 8 horas
Estaciones de trabajo de reemplazo	Depósito de la Dirección de TICs	5 notebooks preconfiguradas	Inmediata
Tablets de reemplazo	Depósito de la Dirección de TICs	Stock del 10 % del parque	Inmediata en Sede; 48 horas en delegaciones del interior
Conectividad alterna	Enlaces 4G/5G en Sede y delegaciones	Conmutación automática	Inmediata
Energía	UPS y grupo electrógeno en Sede Central	Respaldo local	Autonomía de 8 horas
Operación manual sustitutiva	Planillas en papel en delegaciones y campamentos	Procedimiento aprobado por Contaduría	Permanente

4.10. Alarma y activación del plan

Eventos que disparan la activación (nivel 3 o superior):

- Cifrado, indisponibilidad o alteración no autorizada de la base de datos de certificaciones.
- Indisponibilidad del ERP Vial por más de 30 minutos en horario de operación.
- Caída simultánea de la VPN de dos o más Delegaciones Zonales por más de 4 horas.
- Incendio, inundación o corte de energía sin respaldo en la Sede Central.
- Hurto de más de tres dispositivos institucionales en un mismo evento.
- Detección de acceso no autorizado a los módulos que administran el Fondo Vial.

Medios de notificación y árbol de llamadas

1. Alerta automática del sistema de monitoreo a la Mesa de Ayuda (correo y mensaje al celular de guardia).
2. La Mesa de Ayuda comunica **dentro de los 15 minutos** al Jefe del Dpto. de Infraestructura y al Jefe de la División Ciberseguridad.
3. El Líder Técnico evalúa el nivel de gravedad e informa **dentro de los 30 minutos** al Director de TICs, quien **declara formalmente la contingencia** y convoca al Comité de Crisis.
4. El Director de TICs notifica al Administrador General y a los Jefes de las 5 Delegaciones Zonales por vía telefónica y por el grupo institucional de mensajería, con confirmación de recepción de cada uno.
5. Toda comunicación externa se canaliza exclusivamente por la vocería institucional.

4.11. Procedimiento de recuperación (metodología de Lardent)

1. **Protección de la vida humana.** Evacuación conforme al protocolo de Seguridad e Higiene; recuento del personal. Ninguna tarea técnica se inicia antes de completar este paso.
2. **Evaluación de daños.** El Líder Técnico y el Responsable de Seguridad relevan el alcance sobre datos, equipamiento e instalaciones, y clasifican el evento según los cinco niveles del punto 4.2.

3. **Declaración formal de la contingencia.** El Coordinador General declara la contingencia, deja constancia en acta y activa el árbol de llamadas.
4. **Contención y preservación de la evidencia.** Aislamiento de los segmentos afectados, bloqueo de credenciales comprometidas y resguardo de registros para el análisis forense y la eventual denuncia.
5. **Restauración en el sitio alternativo.** Conmutación al centro de datos de réplica de ECOM Chaco y restauración de la última copia verificada, respetando el orden de prioridades del punto 4.7.
6. **Conmutación de la red y habilitación de puestos.** Redireccionamiento de los túneles VPN de las 5 delegaciones y puesta en servicio del sitio alterno de trabajo.
7. **Operación en modo degradado.** Las delegaciones y campamentos operan con los procedimientos manuales aprobados, elevando parte diario al Referente Zonal.
8. **Conciliación y fusión de datos.** Carga y validación de la información procesada manualmente, conforme al orden del punto 4.8, con acta de conciliación por etapa.
9. **Retorno a la normalidad.** Verificación funcional completa, declaración de cierre de la contingencia por el Coordinador General y regreso a la operación habitual.
10. **Informe de auditoría y lecciones aprendidas.** Informe al Administrador General dentro de los 10 días hábiles, con causa raíz, RTO y RPO efectivamente alcanzados frente a los objetivos, costos incurridos y plan de mejoras.

4.12. Logística

- **Traslado de personal:** el Departamento de Soporte y Atención al Usuario dispone de las movilidades del organismo para el traslado del personal esencial al sitio alterno, con listado nominal preestablecido.
- **Comunicaciones durante la contingencia:** telefonía celular institucional y grupo de mensajería del Comité de Crisis como canales primarios; radio VHF de la DVP como canal alternativo hacia campamentos sin cobertura.
- **Abastecimiento:** provisión de formularios preimpresos (actas de medición y planillas de despacho de combustible) en cada delegación y campamento, con reposición trimestral.

- **Operación de los campamentos:** el despacho de combustible continúa registrándose en planilla papel con firma del responsable de campamento, resguardándose el original para su posterior carga y conciliación.
- **Reintegro:** finalizada la contingencia, el equipamiento y la documentación retornan a la Sede Central bajo acta de traslado firmada por el Responsable de Logística y Usuarios.

4.13. Mantenimiento y puesta a prueba del plan

- **Simulacro semestral completo** con participación del Comité de Crisis y de al menos dos Delegaciones Zonales, incluyendo la operación en modo manual y el traslado al sitio alterno.
- **Prueba mensual de restauración** de respaldos sobre un entorno aislado, documentada en acta por el Líder Técnico.
- **Prueba semestral** del grupo electrógeno, de la UPS y de la conmutación automática al enlace 4G/5G.
- **Revisión del plan** ante todo cambio significativo de infraestructura, de sistemas o de la estructura organizativa, y como mínimo una vez al año.
- **Indicadores de eficacia:** RTO y RPO reales alcanzados en el simulacro frente a los objetivos; porcentaje de personal capacitado; tasa de clic en las campañas de phishing simulado; cantidad de incidentes reportados y tiempo medio de respuesta.
- Los resultados se elevan al Administrador General y alimentan el ciclo de mejora continua **PHVA (Planificar–Hacer–Verificar–Actuar)** del SGSI.

4.14. Apéndices del plan

Se archivan junto al plan, en versión impresa en Sede Central y en el sitio alterno, y en versión digital en el repositorio cifrado de la Dirección de TICs:

- Pólizas de seguro técnico y de ciberriesgo vigentes.
- Contrato de IaaS y SLA con ECOM Chaco, y contratos de conectividad.
- Nómina del Comité de Crisis con teléfonos, suplentes y árbol de llamadas actualizado.
- Inventario detallado de hardware, software y licencias, con números de serie.
- Planos de evacuación de la Sede Central y de las 5 Delegaciones Zonales.

- Procedimientos manuales sustitutivos aprobados por Contaduría y formularios modelo.
- Resultados del análisis de riesgos (Fases I a III) y actas de los simulacros realizados.
- Directorio de contactos de emergencia: ECOM Chaco, CERT.ar, proveedor de conectividad, aseguradora, bomberos y policía.

4.15. Aplicación de la norma IRAM-ISO/IEC 27001 en la Fase IV

Dominio / Control	**Aplicación concreta en el plan de contingencia de la DVP**
A.5 Políticas de Seguridad	Aprobación del DRP por resolución del Administrador General como política institucional de continuidad.
A.6 Organización de la Seguridad	Conformación formal del Comité de Crisis con roles, responsabilidades y suplentes definidos (punto 4.6).
A.7 Seguridad en los RRHH	Capacitación del personal en los procedimientos del plan y participación obligatoria en los simulacros semestrales.
A.11 Seguridad Física y del Entorno	Sitio alterno de trabajo, UPS, grupo electrógeno y protocolo de evacuación.
A.12 Seguridad Operacional	Esquema de respaldo 3-2-1 con prueba mensual de restauración y registro de incidentes.
A.15 Relación con Proveedores	SLA con RTO de 4 horas y RPO de 12 horas, réplica en segundo centro de datos y derecho a auditoría sobre ECOM Chaco.
A.16 Gestión de Incidentes	Árbol de llamadas, preservación de evidencia forense, comunicación al CERT.ar e informe de lecciones aprendidas.
A.17 Continuidad del Negocio	Institucionalización del DRP con prioridades de recuperación, sitio alterno y pruebas periódicas documentadas.

Registro de puntos de discusión, acuerdos y desacuerdos (Punto 3)

Punto discutido	**Posiciones**	**Resolución del grupo**
¿Cómo justificar las probabilidades	Se observó que los porcentajes, tomados sin	**Acuerdo:** se incorpora una escala cualitativa/cuantitativa (Baja / Media / Alta) y se documentan los

asignadas en la Fase II?	criterio explícito, resultaban arbitrarios.	supuestos de valuación de cada pérdida potencial.
¿Corresponde cuantificar la amenaza física accidental?	La matriz de la Fase I incluía incendio, inundación y cortes de energía, pero la tabla de ALE no los valuaba.	**Acuerdo:** se incorpora la fila correspondiente a instalaciones, ya que es el supuesto que sustenta el nivel de *catástrofe* de la Fase IV.
¿Las políticas de seguridad se definen de manera general o por amenaza?	Una postura sostenía definirlas por amenaza, para que cada contramedida tuviera su norma asociada; otra, redactarlas en forma general para el organismo.	**Acuerdo:** se definen por amenaza y luego se consolidan en la Política General de la DVP (punto 3.9), cubriendo ambos niveles.
¿Corresponde clasificar los controles por tipo?	Se evaluó si agregaba valor distinguir control físico/lógico y general/de aplicación.	**Acuerdo:** se incorpora la clasificación en cada par activo–amenaza, por recomendación recibida en el Taller de Seguridad.
¿Transferir el riesgo de hurto de tablets mediante seguro?	Una postura señalaba que el costo de la póliza podía superar el valor del parque; otra priorizaba la previsibilidad presupuestaria.	**Acuerdo:** se transfiere el riesgo patrimonial del equipamiento y se reduce por separado el riesgo sobre la información (MDM, cifrado, borrado remoto).
¿Se justifica el enlace redundante de la VPN si su costo se aproxima al beneficio?	Observación surgida del cuadro de costo-beneficio (punto 3.10).	**Desacuerdo parcial, resuelto:** se sostiene la inversión porque la conectividad es condición habilitante de todos los demás controles y del cumplimiento del RTO. Se deja constancia de la observación.
¿El sitio alterno debe ser propio o contratado?	Se discutió entre un sitio alterno provisto por el	**Acuerdo:** procesamiento en el segundo centro de datos del proveedor y puestos de trabajo en la

	proveedor y el uso de una dependencia propia.	Delegación Zonal Resistencia, por costo cero de infraestructura adicional.
Nivel a partir del cual se activa el plan	Se discutió si activarlo ante toda interrupción o sólo ante eventos mayores.	**Acuerdo:** el plan se activa a partir del nivel 3; los niveles 1 y 2 los resuelve la Mesa de Ayuda.